

TEHDİT MÜHENDİSLİĞİ

[Kaynak](#)

Summit

PicoSecure ortamında yürütülen Tehdit Simülasyonu ve Tespit Mühendisliği (Detection Engineering) testlerinin detaylı analizini ve savunma stratejilerini içermektedir. Amacımız, kademeli olarak zorlaşan zararlı yazılım (malware) örneklerini analiz etmek, davranışlarını anlamak ve onlara karşı en uygun engelleme (blocking) kurallarını oluşturmaktır.

Aşama 1: Dosya İmza (Hash) Tabanlı Tespit ve Engelleme

Sızma testi uzmanı "Sphinx" tarafından iletilen ilk zararlı yazılım örneği olan `sample1.exe` dosyası **Malware Sandbox** (Zararlı yazılımı güvenli ve izole bir ortamda çalıştırıp davranışlarını analiz eden sistem) üzerinde incelenmiştir.

General Info - sample1.exe

File Name	sample1.exe
File Size	202.50 KB
File Type	PE32+ executable (GUI) x86-64, for MS Windows
Analysis Date	September 5, 2023
OS	Windows 10x64 v1803
Tags	Trojan.Metasploit.A
MIME	application/x-dosexec
MD5	cbda8ae000aa9cbe7c8b982bae006c2a
SHA1	83d2791ca93e58688598485aa62597c0ebbf7610
SHA256	9c550591a25c6228cb7d74d970d133d75c961ffed2ef7180144859cc09efca8c

Behaviour Analysis

MALICIOUS

METASPLOIT was detected

- sample1.exe (PID: 2492)

SUSPICIOUS

Connects to unusual port

- sample1.exe (PID: 2492)

INFO

Reads the machine GUID from the registry

- sample1.exe (PID: 2492)

The process checks LSA protection

- sample1.exe (PID: 2492)

Reads the computer name

- sample1.exe (PID: 2492)

Checks supported languages

- sample1.exe (PID: 2492)

Analiz Çıktısı ve Teknik Yorum: Sandbox analizi sonucunda `sample1.exe` dosyasının **PE32+ executable (GUI) x86-64** formatında bir Windows çalıştırılabilir dosyası olduğu tespit edilmiştir. İlgili dosya **Trojan.Metasploit.A** olarak etiketlenmiştir. Davranışsal analizde, dosyanın makine GUID değerini ve bilgisayar adını okuduğu, LSA (Local Security Authority) korumasını kontrol ettiği görülmektedir.

En kritik bulgu ise dosyanın kriptografik özetleridir (Hash):

MD5: cbda8ae000aa9cbe7c8b982bae006c2a

SHA1: 83d2791ca93e58688598485aa62597c0ebbf7610

SHA256: 9c550591a25c6228cb7d74d970d133d75c961ffed2ef7180144859cc09efca8c

Neden Hash Filtrelemesi Kullanıyoruz? İlk savunma hattı olarak **IoC (Indicator of Compromise - Uzlaşma Göstergesi)** listesine bu dosyanın **SHA256** hash değerini ekliyoruz. Hash değerleri, bir dosyanın dijital parmak izidir. Aynı hash değerine sahip bir dosya ağda bir daha görülürse, sistem bunun kesinlikle aynı zararlı yazılım olduğunu %100 doğrulukla (Highest Confidence) bilir ve çalışmasını engeller.

Aksiyon: Manage Hashes arayüzü üzerinden "SHA256" algoritması seçilmiş ve 9c550591a25c6228cb7d74d970d133d75c961ffed2ef7180144859cc09efca8c değeri kara listeye (Blocklist) eklenerek zararlının çalışması durdurulmuştur.

ÖNEMLİ: Hash engellemesi çok kesin bir yöntem olsa da, modern saldırganlar için atlatması (bypass) en kolay yöntemdir. Saldırgan kaynak kodu yeniden derlediğinde (recompile) veya dosya içerisindeki tek bir biti bile değiştirdiğinde bu hash değeri tamamen değişecek ve kuralımız işlevsiz kalacaktır.

Aşama 2: Ağ Katmanı ve IP Tabanlı Egress Filtreleme

Beklendiği gibi, saldırgan zararlı yazılımı yeniden derleyerek hash değerini değiştirmiş ve sample2.exe dosyasını sisteme sokmuştur. Bu durumda statik analiz (hash tespiti) işe yaramadığı için **Dinamik Analiz** (zararlının çalışma anındaki ağ/sistem davranışlarını inceleme) aşamasına geçiyoruz.

Analiz Çıktısı ve Teknik Yorum: sample2.exe Malware Sandbox üzerinde çalıştırıldığında, **Network Activity** (Ağ Aktivitesi) sekmesinde kritik bir anomali tespit edilmiştir.

Upload Sample

Select a file from the drop-down menu. The automated analysis engine will execute the suspicious file on the target sandbox system to detect malware and malicious behaviour.

File: sample2.exe

Submit for Analysis

General Info - sample2.exe

File Name	sample2.exe
File Size	202.73 KB
File Type	PEXE - PE32+ executable (GUI) x86-64, for MS Windows
Analysis Date	September 5, 2023
OS	Windows 10x64 v1803
Tags	Trojan.Metasploit.A
MIME	application/x-dosexec
MD5	4d661bf605d6b0b15915a533b572a6bd
SHA1	6878976974c27c8547cfc5acc90fb28ad2f0e975
SHA256	d576245e85e6b752b2fdffa43abaab1b2e1383556b0169fd04924d6cebc1cdf9

Behaviour Analysis

MALICIOUS

METASPLOIT was detected

- sample2.exe (PID: 1927)

SUSPICIOUS

Connects to unusual IP address

- sample2.exe (PID: 1927)

Connects to unusual port

- sample2.exe (PID: 1927)

INFO

Reads the machine GUID from the registry

- sample2.exe (PID: 1927)

The process checks LSA protection

- sample2.exe (PID: 1927)

Reads the computer name

- sample2.exe (PID: 1927)

Checks supported languages

- sample2.exe (PID: 1927)

Network Activity

HTTP(S) requests	TCP/UDP connections	DNS requests	Threats
1	3	0	0

HTTP requests

PID	Process	Method	IP	URL
1927	sample2.exe	GET	154.35.10.113:4444	http://154.35.10.113:4444/uvLk8YI32

Connections

PID	Process	IP	Domain	ASN
1927	sample2.exe	154.35.10.113:4444	-	Intrabuzz Hosting Limited
1927	sample2.exe	40.97.128.3:443	-	Microsoft Corporation
1927	sample2.exe	40.97.128.4:443	-	Microsoft Corporation

HTTP requests

PID: 1927 | Process: sample2.exe | Method: GET | IP: 154.35.10.113:4444 |
URL: http://154.35.10.113:4444/uvLk8Yl32

Burada zararlı yazılımın dışarıdaki bir IP adresine (**154.35.10.113**) bağlantı kurmaya çalıştığını görüyoruz. Bağlantının **4444** portu üzerinden gerçekleşmesi dikkat çekicidir; zira 4444, Metasploit Framework'ün varsayılan dinleyici (listener) portudur. Zararlı yazılım, kurban makineden saldırganın **C2 (Command and Control - Komuta Kontrol)** sunucusuna bir bağlantı başlatmaya çalışmaktadır.

Aksiyon: Hash değerleri değişse de, saldırganın komuta kontrol sunucusunun IP adresi şu an için sabittir. Bu iletişimi kesmek için **Firewall Rule Manager** (Güvenlik Duvarı Kural Yöneticisi) üzerinden bir kural yazılmalıdır.

Firewall Rule Manager

Home / IOC Management / Firewall Rule Manager

Create Firewall Rule

Type: Egress

Source IP: Any

Destination IP: 154.35.10.113

Action: Deny

Cancel Save Rule

The firewall rule has been added!

Active Rules

Nice work! The firewall rule prevented **sample2.exe** from connecting to the tester's command-and-control server. Check your **inbox** for the next steps.

Enabled	Type	Source	Destination	Action	Settings
Yes	Egress	Any	154.35.10.113	Deny	✎ 🗑
Yes	Egress	10.10.23.45	142.56.78.90	Allow	✎ 🗑
Yes	Ingress	88.90.123.45	Any	Deny	✎ 🗑
Yes	Ingress	203.56.78.90	Any	Deny	✎ 🗑
Yes	Egress	Any	205.78.90.12	Allow	✎ 🗑
Yes	Ingress	121.111.13.14	Any	Deny	✎ 🗑
Yes	Ingress	187.123.45.67	10.10.32.45	Allow	✎ 🗑
Yes	Ingress	154.67.89.23	10.10.56.78	Allow	✎ 🗑
Yes	Egress	Any	95.123.45.67	Deny	✎ 🗑
Yes	Egress	10.10.45.67	180.23.45.67	Deny	✎ 🗑

- **Type (Yön): Egress** (Dışarı çıkan trafik). Çünkü kurban makine (içerisi), saldırganın sunucusuna (dışarı) istek yapmaktadır.
- **Source IP (Kaynak): Any** (Ağıdaki herhangi bir makineden bu C2'ye giden tüm istekleri yakalamak için).
- **Destination IP (Hedef): 154.35.10.113** (Saldırganın C2 IP adresi).
- **Action (Eylem): Deny** (Engelle).

DİKKAT: Bu adımda "Egress" yerine "Ingress" (İçeri giren trafik) kuralı yazsaydık, saldırı durmazdı. Çünkü saldırı modeli bir **Reverse Shell** (Ters Bağlantı) yapısı kurgulamaktadır; yani bağlantıyı başlatan taraf dışarıdaki saldırgan değil, içerideki zararlı yazılımdır.

Aşama 3: DNS Seviyesinde Tespit ve Engelleme

Saldırgan, güvenlik duvarından IP adresinin engellendiğini fark edince taktik değiştirmiştir. Bulut servis sağlayıcıları sayesinde saniyeler içinde yeni genel (public) IP adresleri tahsis edebilmektedir. Bu nedenle statik IP engellemek artık sürdürülebilir değildir. Yeni zararlı **sample3.exe** analiz ediliyor.

Malware Sandbox

Home / Malware Sandbox

Upload Sample

Select a file from the drop-down menu. The automated analysis engine will execute the suspicious file on the target sandbox system to detect malware and malicious behaviour.

File: sample3.exe

Submit for Analysis

General Info - sample3.exe

File Name

sample3.exe

File Size

207.12 KB

File Type

PEXE - PE32+ executable (GUI) x86-64, for MS Windows

Analysis Date

September 5, 2023

OS

Windows 10x64 v1803

Tags

Trojan.Metasploit.A

MIME

application/x-dosexec

MD5

e31f8c62927d9d5a897b4c45e3c64dbc

SHA1

a92d3de6b1e3ab295f18587ca75f15318cb85a7b

SHA256

acfb9b1268bcd08a465f9f300ac463b9b1215c897ebe44618359bb80881fe6a05

Behaviour Analysis

MALICIOUS

METASPLOIT was detected

- sample3.exe (PID: 1021)

Downloads executable files from the internet

- backdoor.exe (PID: 2712)

SUSPICIOUS

Connects to unusual IP address

- sample3.exe (PID: 1021)

Connects to unusual port

- sample3.exe (PID: 1021)

INFO

Reads the machine GUID from the registry

- sample3.exe (PID: 1021)

The process checks LSA protection

- sample3.exe (PID: 1021)

Reads the computer name

- sample3.exe (PID: 1021)

Checks supported languages

- sample3.exe (PID: 1021)

Analiz Çıktısı ve Teknik Yorum: sample3.exe dosyası analiz edildiğinde, **Network Activity** altında doğrudan bir IP'ye gitmek yerine önce bir **DNS Request** (Alan Adı Çözümleme İsteği) yaptığı görülmektedir.

Network Activity

HTTP(S) requests

2

TCP/UDP connections

4

DNS requests

2

Threats

0

HTTP requests

PID	Process	Method	IP	URL
1021	sample3.exe	GET	62.123.140.9:1337	http://emudyn.bresonicz.info:1337/kzn293la
1021	sample3.exe	GET	62.123.140.9:80	http://emudyn.bresonicz.info/backdoor.exe

Connections

PID	Process	IP	Domain	ASN
1021	sample3.exe	40.97.128.4:443	services.microsoft.com	Microsoft Corporation
1021	sample3.exe	62.123.140.9:1337	emudyn.bresonicz.info	Xplorita Cloud Services
1021	sample3.exe	62.123.140.9:80	emudyn.bresonicz.info	Xplorita Cloud Services
2712	backdoor.exe	62.123.140.9:80	emudyn.bresonicz.info	Xplorita Cloud Services

DNS requests

Domain	IP
services.microsoft.com	40.97.128.4
emudyn.bresonicz.info	62.123.140.9

DNS requests

Domain: emudyn.bresonicz.info | IP: 62.123.140.9

HTTP requests

PID: 1021 | Process: sample3.exe | Method: GET | IP: 62.123.140.9:1337 | URL: http://emudyn.bresonicz.info:1337/kzn293la
PID: 1021 | Process: sample3.exe | Method: GET | IP: 62.123.140.9:80 | URL: http://emudyn.bresonicz.info/backdoor.exe

Buradaki arka plan mantığı şudur: Saldırgan C2 sunucusunun IP adresini gizlemek ve esneklik kazanmak için zararlı yazılımın içine IP adresi yazmak yerine `emudyn.bresonicz.info` alan adını (domain) gömmüştür. Eğer biz sadece `62.123.140.9` IP'sini engellersek, saldırı DNS kaydını güncelleyerek bu alan adını başka bir IP'ye yönlendirebilir ve bağlantıyı kurtarabilir (**Fast-Flux** tekniği). Zararlı yazılım aynı zamanda sisteme ek bir `backdoor.exe` (Arka kapı - sisteme kalıcı erişim sağlamak için indirilen ikincil zararlı) indirmeye çalışmaktadır.

Aksiyon: Saldırganın altyapısını kökünden felç etmek için IP seviyesinden bir üst katmana, **DNS (Domain Name System)** seviyesine çıkıyoruz. Hedef domain adresi kara listeye alınırsa, bu domain hangi IP adresine çözümlenirse çözümlensin cihazlarımızın bu adrese erişimi işletim sistemi veya kurumsal DNS sunucusu tarafından reddedilecektir.

DNS Rule Manager

Home / IOC Management / DNS Rule Manager

Create DNS Rule

Rule Name:

Category:

Domain Name:

Action:

Denying a domain will automatically include all its subdomains, but denying a subdomain will not automatically include the main domain. Deny rules will take precedence over any preconfigured allow rules.

The DNS rule has been added!

Active Rules

Nice work! The DNS filter rule prevented `sample3.exe` from connecting to the tester's command-and-control server. Check your **inbox** for the next steps.

Rule Name	Category	Domain	Action	Settings
Cloud Service	Malware	emudyn.bresonicz.info	Deny	☒ ☐
Cryptomining proxy server	Cryptomining	proxy4crypto.net	Deny	☒ ☐
Gambling referral site	Gambling	luckylottoaffiliates.com	Deny	☒ ☐
Anonymous browsing service	Anonymizer	cloakandbrowseanon.xyz	Deny	☒ ☐
Conspiracy theorist cat blog	Other	catsknowthetruth.info	Allow	☒ ☐
Suspicious file-sharing domain	Malware	downloadmyfilez.biz	Deny	☒ ☐
C2 server associated subdomain	Botnet	commandn.ctrl.xyz	Deny	☒ ☐
Fake software updates	Malware	legitsft-updates.info	Deny	☒ ☐
Bill's wedding invite (Allow)	Other	billsvp.myweddings.io	Allow	☒ ☐
Deny known phishing domain	Phishing	parrotpost.thm	Deny	☒ ☐

ÖNEMLİ: Bir ana domain'in (domain.com) engellenmesi, hiyerarşik yapı gereği ona bağlı olan alt alan adlarının (subdomain) yani `x.domain.com` veya `y.domain.com` adreslerinin de iletişimini otomatik olarak kesecektir. Bu, esnek ve kalıcı bir savunma hamlesidir.

Aşama 4: Host-Based (Uç Nokta) Tespit ve Registry (Kayıt Defteri) Analizi

Saldırgan (Sphinx), ağ katmanındaki (IP ve DNS) engellemelerimizi aşmak için taktiksel bir değişime gitmiştir. Hasher, IP adresleri ve Domain isimleri **Pyramid of Pain (Acı Piramidi)** modelinde saldırırganın değiştirmesi en kolay olan ve savunmacı için en düşük güvenilirlikli (low-confidence) göstergelerdir. Bu nedenle saldırırgan, `sample4.exe` ile bizi uç nokta (**Endpoint/Host**) üzerinde bıraktığı izleri (Artifacts) bulmaya zorlamaktadır.

Malware Sandbox

Home / Malware Sandbox

Upload Sample

Select a file from the drop-down menu. The automated analysis engine will execute the suspicious file on the target sandbox system to detect malware and malicious behaviour.

File: sample4.exe

Submit for Analysis

General Info - sample4.exe

File Name

sample4.exe

File Size

219.46 KB

File Type

PEXE - PE32+ executable (GUI) x86-64, for MS Windows

Analysis Date

September 5, 2023

OS

Windows 10x64 v1803

Tags

None

MIME

application/x-dosexec

MD5

5f29ff19d99fe244eaf5835ce01a4631

SHA1

cd12d2328f700ae1ba1296a5f011bfc5a49f456d

SHA256

a80cffb40cea83c1a20973a5b803828e67691f71f3c878edb5a139634d7dd422

Behaviour Analysis

MALICIOUS

Disables Windows Defender Real-time monitoring

- sample4.exe (PID: 3806)

Downloads executable files from the Internet

- backdoor.exe (PID: 1367)

SUSPICIOUS

Connects to unusual IP address

- sample4.exe (PID: 3806)

Connects to unusual port

- sample4.exe (PID: 3806)

Makes changes to the registry

- sample4.exe (PID: 3806)

INFO

Reads the machine GUID from the registry

- sample4.exe (PID: 3806)

The process checks LSA protection

- sample4.exe (PID: 3806)

Reads the computer name

- sample4.exe (PID: 3806)

Checks supported languages

- sample4.exe (PID: 3806)

Analiz Çıktısı ve Teknik Yorum: sample4.exe Sandbox üzerinde incelendiğinde, ağ trafiği (Network Activity) sekmesinde cranes0ft.iniware.xyz alan adına gidildiği görülse de, önceki aşamadan biliyoruz ki bu domain'i engellemek geçici bir çözümdür; saldırgan bunu anında değiştirecektir.

Network Activity

HTTP(S) requests

2

TCP/UDP connections

3

DNS requests

1

Threats

0

HTTP requests

PID	Process	Method	IP	URL
3806	sample4.exe	GET	102.23.20.118:1337	http://cranes0ft.iniware.xyz:1337/ab9z83ja
3806	sample4.exe	GET	102.23.20.118:80	http://cranes0ft.iniware.xyz/backdoor.exe

Connections

PID	Process	IP	Domain	ASN
3806	sample4.exe	102.23.20.118:1337	cranes0ft.iniware.xyz	Xplorita Cloud Services
3806	sample4.exe	102.23.20.118:80	cranes0ft.iniware.xyz	Xplorita Cloud Services
1367	backdoor.exe	102.23.20.118:80	cranes0ft.iniware.xyz	Xplorita Cloud Services

DNS requests

Domain	IP
cranes0ft.iniware.xyz	102.23.20.118

Asıl kritik bulgu **Registry Activity (Kayıt Defteri Aktivitesi)** sekmesinde yatmaktadır:

DNS requests

Domain	IP
cranesoft.iniware.xyz	102.23.20.118

Registry Activity

Total events	Read events	Write events	Delete events
3	1	2	0

Modification events

(PID) Process: (3806) sample4.exe	Key: HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows Defender\Real-Time Protection
Operation: write	Name: DisableRealtimeMonitoring
Value: 1	
(PID) Process: (1928) explorer.exe	Key: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\Advanced
Operation: write	Name: EnableBalloonTips
Value: 1	
(PID) Process: (9876) notepad.exe	Key: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\FileExts\.txt
Operation: read	Name: Progid
Value: txtfile	

```
(PID) Process: (3806) sample4.exe
Operation: write
Key: HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows Defender\Real-Time
Protection
Name: DisableRealtimeMonitoring
Value: 1
```

Bu log satırı, zararlı yazılımın sistemde kalıcılık sağlamak ve tespit edilmeden çalışmak için yerleşik antivirüs korumasını (Windows Defender) kör etmeye çalıştığını kanıtlar. Zararlı yazılım, işletim sisteminin beyni olan Kayıt Defteri'ne (Registry) müdahale ederek **DisableRealtimeMonitoring** değerini 1 (Aktif/Doğru) olarak ayarlamakta ve böylece gerçek zamanlı korumayı kapatmaktadır.

Aksiyon: Davranışsal Kural (Sigma Rule) Oluşturma Bu aşamada spesifik bir dosya adını veya hash'i değil, doğrudan **kötü niyetli bir davranış** engellemek için sistem genelinde bir **Sigma Rule** (SIEM ve EDR sistemleri için standartlaştırılmış kural formatı) yazıyoruz.

☒ Registry Modifications

Detect changes to registry keys or values such as system settings, security policies, autorun entries, or access control configurations.

Step 3: Registry Modifications

Set the rule conditions and options:

Registry Key:*	HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows De
Registry Name:*	DisableRealtimeMonitoring
Value:*	1
ATT&CK ID:*	Defense Evasion (TA0005) ▼

At PicoSecure, we require that all Sysmon detection rules map to the [MITRE ATT&CK framework](#). This ensures that our SOC team has the context to facilitate a more effective threat detection, analysis, and response.

Cancel

Validate Rule

Mantıksal Çerçeve: Sistemde herhangi bir process (ister `sample4.exe` olsun, ister saldırganın yarın yazacağı `update.exe` olsun), bu spesifik kayıt defteri anahtarına "1" değerini yazmaya çalıştığı an, EDR (Endpoint Detection and Response) ajanı bu işlemi **EventID: 4663** (Kayıt Defteri Nesne Erişimi) üzerinden yakalayacak ve süreci anında öldürecektir (kill process). Bu kuralı MITRE ATT&CK framework'ünde **Defense Evasion (Savunmadan Kaçınma)** taktiği ile eşleştirmek, SOC (Security Operations Center) analistlerinin alarm düştüğünde saldırının hangi aşamasında olduğunu anlaması için hayati önem taşır.

Sigma Rule Validation

```

title: Modification of Windows Defender Real-Time Protection
id: windows_registry_defender_disable_realtime
description: |
    Detects modifications or creations of the Windows Defender Real-Time Protection DisableRealtimeMonitoring registry value.

references:
  - https://attack.mitre.org/tactics/TA0005/

tags:
  - attack.ta0005
  - sysmon

detection:
  selection:
    EventID: 4663
    ObjectType: Key
    ObjectName: 'HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows Defender\Real-Time Protection'
    NewValue: 'DisableRealtimeMonitoring=1'

  condition: selection

falsepositives:
  - Legitimate changes to Windows Defender settings.

level: high

```

Aşama 5: Davranışsal Ağ Analizi ve C2 Beaconsing (Sinyalizasyon) Tespiti

Saldırgan, uç noktada bıraktığı statik izlerin (Registry değişiklikleri gibi) de yakalandığını fark edince, zararlı yazılımın mimarisini tamamen değiştirerek `samp1e5.exe` 'yi devreye sokuyor. Bu yeni varyantta saldırgan, tüm komut işleme yükünü kendi arka uç (backend) sunucusuna taşımış durumdadır. Bize sadece kurban makinenin son 12 saatlik giden ağ bağlantısı loglarını (`outgoing_connections.log`) bırakmıştır.



To: You

9/5/2023 12:23 PM

Hey,

I'm not sure what you managed to do this time, but you seriously threw a wrench into my malware sample! I spent ages trying to reconfigure my attack tools and methodologies to get around your detection - SUPER ANNOYING!

Having my team develop new techniques used in my adversary tools was a time-consuming effort and a significant cost. It's good that we have a substantial budget for this engagement, but many threat actors would have given up and found a new victim by now.

I finally have `sample5.exe` for you to detect. Different approach this time. In this sample, all of the "heavy lifting" and instruction occurs on my backend server, so I can easily change the types of protocols I use and the artifacts I leave on the host. You'll have to find something unique or abnormal about the behaviour of my tool to detect it.

I attached the logs of the outgoing network connections from the last 12 hours on the victim machine. That may help you correlate something.

I don't know what to do if you can stop me at this level.

Here's your flag:

THM{[REDACTED]}

2023-08-15 09:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 09:23:45	Source: 10.10.15.12	Destination: 43.10.65.115	Port: 443	Size: 21541 bytes
2023-08-15 09:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 10:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 10:14:21	Source: 10.10.15.12	Destination: 87.32.56.124	Port: 80	Size: 1204 bytes
2023-08-15 10:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 11:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 11:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 11:45:09	Source: 10.10.15.12	Destination: 145.78.90.33	Port: 443	Size: 805 bytes
2023-08-15 12:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 12:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 13:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 13:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 13:32:17	Source: 10.10.15.12	Destination: 72.15.61.98	Port: 443	Size: 26084 bytes
2023-08-15 14:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 14:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 14:55:33	Source: 10.10.15.12	Destination: 208.45.72.16	Port: 443	Size: 45091 bytes
2023-08-15 15:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 15:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 15:40:10	Source: 10.10.15.12	Destination: 101.55.20.79	Port: 443	Size: 95021 bytes
2023-08-15 16:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 16:18:55	Source: 10.10.15.12	Destination: 194.92.18.10	Port: 80	Size: 8004 bytes
2023-08-15 16:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 17:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 17:09:30	Source: 10.10.15.12	Destination: 77.23.66.214	Port: 443	Size: 9584 bytes
2023-08-15 17:27:42	Source: 10.10.15.12	Destination: 156.29.88.77	Port: 443	Size: 10293 bytes
2023-08-15 17:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 18:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 18:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes

Tehdit Avcılığı (Threat Hunting) ve Log Analizi: Verilen log dosyasını incelediğimizde, gürültülü (noisy) trafik arasında mükemmel bir matematiksel döngüyle tekrar eden bir anomali göze çarpmaktadır:

```
2023-08-15 09:00:00 | Source: 10.10.15.12 | Destination: 51.102.10.19 |  
Port: 443 | Size: 97 bytes  
2023-08-15 09:30:00 | Source: 10.10.15.12 | Destination: 51.102.10.19 |  
Port: 443 | Size: 97 bytes  
2023-08-15 10:00:00 | Source: 10.10.15.12 | Destination: 51.102.10.19 |  
Port: 443 | Size: 97 bytes  
2023-08-15 10:30:00 | Source: 10.10.15.12 | Destination: 51.102.10.19 |  
Port: 443 | Size: 97 bytes  
...
```

Arka Plandaki Teknik Anlam: Bu yapı siber güvenlik terminolojisinde **Beaconing** (Sinyalizasyon/Kalp Atışı) olarak adlandırılır. Gelişmiş zararlı yazılımlar (özellikle Cobalt Strike, Covenant gibi C2 framework'leri), ağda sürekli bir bağlantı açık tutarak güvenlik duvarlarının dikkatini çekmek istemezler. Bunun yerine "uyku" (sleep) moduna geçerler ve periyodik olarak uyanıp C2 sunucusuna "Ben buradayım, yeni bir komutun var mı?" diye sorarlar.

Burada saldırganın zararlısı, **tam olarak her 30 dakikada bir (1800 saniye)** C2 sunucusuna bağlanmakta ve **tam olarak 97 byte** boyutunda bir kontrol paketi göndermektedir. Normal bir insan veya meşru bir uygulama trafiği asla bu kadar kusursuz bir zamanlamaya ve sabit paket boyutuna sahip olamaz (Saldırgan, tespit edilmemek için Jitter -zaman sapması- değerini ayarlamayı unutmuş veya yapılandırmamıştır).

Aksiyon: TTP (Taktik, Teknik ve Prosedür) Odaklı Tespit Kuralı Saldırganın kullandığı IP adresini veya Portu engellemek işe yaramayacaktır. Bunun yerine, zararlı yazılımın **ağ üzerindeki kalıtsal davranışını** engellemeliyiz.

Step 3: Network Connections

Set the rule conditions and options:

This rule will detect network connections made from a host machine with specific conditions, such as remote IP, port, size of the connection, and how often it occurs (frequency).

Remote IP:*	any
Remote Port:*	any
Size (bytes):*	97
Frequency (seconds):*	1800
ATT&CK ID:*	Command and Control (TA0011)

At PicoSecure, we require that all Sysmon detection rules map to the [MITRE ATT&CK framework](#). This ensures that our SOC team has the context to facilitate a more effective threat detection, analysis, and response.

Cancel

Validate Rule

- **Remote IP:** any (IP değişebilir, umrumuzda değil)
- **Remote Port:** any (Port 443'ten 8080'e geçebilir, umrumuzda değil)
- **Size (bytes):** 97 (Saldırganın C2 profilinin standart paket boyutu)
- **Frequency (seconds):** 1800 (Zararlıının hardcoded edilmiş uyku süresi)
- **ATT&CK ID:** Command and Control (TA0011)

```
title: Alert on Suspicious Beacon Network Connections
id: network_connections_criteria_sysmon
description: |
    Detects network connections with specific criteria in Sysmon logs: remote IP, remote port, size, and frequency.

references:
    - https://attack.mitre.org/tactics/TA0011/

tags:
    - attack.ta0011
    - sysmon

detection:
    selection:
        EventID: 3
        RemoteIP: '*'
        RemotePort: '*'
        Size: 97
        Frequency: 1800 seconds

    condition: selection

falsepositives:
    - Legitimate network traffic may match this criteria.

level: high
```

Neden Bu Parametreler? Saldırgan IP adresini veya domainini saniyeler içinde değiştirebilir. Ancak paket boyutunu (97 byte) ve Beacon frekansını (1800 saniye) değiştirmek, saldırganın zararlı yazılımın kaynak kodunu, C2 altyapısındaki Malleable C2 profilini (iletişim şablonunu) tamamen yeniden yapılandırmasını gerektirir. Biz burada Pyramid of Pain'in zirvesine (**TTPs**) saldırıyoruz. EDR (Sysmon EventID: 3 - Network Connection) bu spesifik koşulları sağlayan her türlü trafiği nerede görürse görsün, C2 iletişimini anında koparacaktır.

Aşama 6: Pyramid of Pain'in Zirvesi - TTP (Taktik, Teknik ve Prosedür) Temelli Tespit

Saldırgan (Sphinx), ağ beaconing (sinyalizasyon) davranışının da engellenmesinin ardından adeta duvara çarpmış durumdadır. E-postasında belirttiği "Yatırımın getirisi artık maliyeti karşılamıyor" ifadesi, siber güvenliğin en temel gerçeklerinden birini özetler: **Savunmacının asıl amacı saldırganı tamamen yok etmek değil, saldırı maliyetini (zaman, efor, para) saldırganın pes edeceği seviyeye kadar yükseltmektir.**

Saldırgan artık Hash, IP, Domain veya basit araç imzalarını değiştirmeyi bırakıp, **Pyramid of Pain (Acı Piramidi)** modelinin en tepesine, yani **TTP (Tactics, Techniques, and Procedures - Taktikler, Teknikler ve Prosedürler)** katmanına itilmiştir. Bir saldırganın kullandığı aracı değiştirmesi kolaydır, ancak "bilgisayarı ele geçirdiğinde ne tür komutlar çalıştırdığı" veya "verileri nasıl topladığı" gibi bilinçaltına yerleşmiş alışkanlıklarını (prosedürlerini) değiştirmesi son derece zordur.

RE: New Approach

👤 Sphinx <sphinx@pentesting.thm>

👤 To: You

📧 📧 📧 9/5/2023 1:02 PM

Hello again,

You managed to detect `sample5.exe` ! I'm very impressed. But also very annoyed! Because now, I need to go back to the drawing board and create a brand new tool to do what I need to do. If I can't find another one quickly, this will be another significant investment. Also, I will need to train myself all over again on how to use it!

I can keep this up one or two times, but there's no way I can continue after this. The reward no longer outweighs the cost, and I would instead find an easier target with detection capabilities much lower on the pyramid.

For my last trick, I have `sample6.exe`. This time, you will need more than artifacts or tool detection to help you. You'll need to focus on something extremely hard for me to change subconsciously - my techniques and procedures.

I've attached the recorded command logs from all my previous samples to understand better what actions I tend to perform on my victims to extract info once I have remote access. Good luck!

Viewing attachment: `commands.log`

```
dir c:\ >> %temp%\exfiltr8.log
dir "c:\Documents and Settings" >> %temp%\exfiltr8.log
dir "c:\Program Files\" >> %temp%\exfiltr8.log
dir d:\ >> %temp%\exfiltr8.log
net localgroup administrator >> %temp%\exfiltr8.log
ver >> %temp%\exfiltr8.log
systeminfo >> %temp%\exfiltr8.log
ipconfig /all >> %temp%\exfiltr8.log
netstat -ano >> %temp%\exfiltr8.log
net start >> %temp%\exfiltr8.log
```

Analiz Çıktısı ve Teknik Yorum: Saldırganın son kozu olan `sample6.exe` ile birlikte, kurban sistemde çalıştırdığı komutların bir günlüğü (`commands.log`) elimize geçmiştir. Burada odaklanmamız gereken şey komutların kendisinden ziyade, saldırganın **veri toplama (Collection) ve sızdırma (Exfiltration)** prosedürüdür. Saldırgan hangi aracı kullanırsa kullansın, çalıştırdığı tüm keşif komutlarının (`dir` , `netstat` , `ipconfig` vb.) çıktısını tek bir dosyada birleştirmektedir: `>> %temp%\exfiltr8.log`

Bu kalıtsal davranış, saldırganın en büyük zafiyetidir. Zararlı yazılım bellekte (RAM) ne kadar gizlenirse gizlensin veya ağ trafiğini ne kadar şifrelerse şifrelesin, topladığı verileri fiziksel diske (Disk I/O) yazmak zorundadır.

Aksiyon: Dosya Oluşturma (File Creation) Tabanlı Davranışsal Kural Saldırganın bu prosedürünü kökünden engellemek için, Uç Nokta Tespit ve Yanıt (EDR) sistemimizde bir **Dosya Oluşturma ve Değiştirme (File Creation and Modification)** kuralı yazıyoruz.

PicoSecure

or creation of executables or scripts.

Network Connections

Detect outgoing network connections, network traffic patterns, or connections made by specific processes.

Registry Modifications

Detect changes to registry keys or values such as system settings, security policies, autorun entries, or access control configurations.

Step 3: File Creation and Modification

Set the rule conditions and options:

File Path:*

File Name:*

ATT&CK ID:*

At PicoSecure, we require that all Sysmon detection rules map to the **MITRE ATT&CK framework**. This ensures that our SOC team has the context to facilitate a more effective threat detection, analysis, and response.

Viewing attachment: **commands.log**

```
dir c:\ >> %temp%\exfiltr8.log
dir "c:\Documents and Settings" >> %temp%\exfiltr8.log
dir "c:\Program Files\" >> %temp%\exfiltr8.log
dir d:\ >> %temp%\exfiltr8.log
net localgroup administrator >> %temp%\exfiltr8.log
ver >> %temp%\exfiltr8.log
systeminfo >> %temp%\exfiltr8.log
ipconfig /all >> %temp%\exfiltr8.log
netstat -ano >> %temp%\exfiltr8.log
net start >> %temp%\exfiltr8.log
```

- **File Path (Dosya Yolu):** %temp%
- **File Name (Dosya Adı):** exfiltr8.log
- **ATT&CK ID: Exfiltration (TA0010)**

Mantıksal Çerçeve ve Teknik Arka Plan: Bu kuralın arka planındaki işletim sistemi dinamiği şudur: EDR ajanları (örneğin Sysmon), Windows Kernel seviyesindeki dosya sistemi filtre sürücülerini (File System Minifilter Drivers) kullanarak diske yapılan her yazma işlemini izler. Sistemde çalışan herhangi bir süreç (ister cmd.exe, ister powershell.exe, isterse saldırganın özel yazdığı sample6.exe olsun), **%temp%** dizini altında (ki bu dizin genellikle C:\Users**<Kullanıcı_Adı>**\AppData\Local\Temp klasörüne çözümlenir) **exfiltr8.log** adında bir dosya yaratmaya veya mevcut bir dosyayı değiştirmeye (modify) çalıştığı anda **Sysmon Event ID 11 (FileCreate)** veya **Event ID 2 (A process changed a file creation time)** logu üretilir.

Kuralımız bu spesifik olayı (Event) yakalayacak şekilde yapılandırılmıştır. Kuralı MITRE ATT&CK framework'ündeki **Exfiltration (Veri Sızdırma - TA0010)** taktiği ile eşleştirmemiz, bu dosyanın sadece zararsız bir log dosyası olmadığını, saldırganın verileri kurum dışına kaçırmadan hemen önceki "paketleme/hazırlık" aşaması olduğunu Güvenlik Operasyon Merkezi'ne (SOC) net bir şekilde bildirir.

Bu kural uygulandığında, saldırgan **sample6.exe** veya gelecekte yazacağı **sample100.exe** ile aynı TTP'yi kullanmaya kalkarsa, daha komutların çıktısı dosyaya yazılamadan süreç anında EDR tarafından engellenecek (Terminate Process) ve saldırı zinciri kırılacaktır. Saldırganın bu engeli aşabilmesi için tüm otomasyon scriptlerini, zararlı yazılım kaynak kodlarını ve operasyonel alışkanlıklarını sıfırdan değiştirmesi gerekecektir ki bu da bizim nihai hedefimizdir.